

Manual 45 — Capstone de Treinamento de Compliance Empresarial

Idioma controlado: português brasileiro (pt-BR). Este capstone é material de treinamento produzido pelo projeto e integra os Manuais Práticos de GRC publicados. Não reproduz texto protegido de normas e não substitui aconselhamento jurídico, regulatório, de auditoria ou certificação.

Chapter 01 — Objetivo do Capstone

Definir cenário, objetivos, direitos de decisão, evidências e critérios de conclusão. O participante deve demonstrar integração de governança, risco, compliance, cibersegurança, privacidade, resiliência, terceiros, nuvem, OT, IA e assurance.

Chapter 02 — Cenário Empresarial

Estabelecer uma empresa multinacional com operações reguladas, nuvem, processos com IA, fornecedores críticos, dados pessoais, obrigações financeiras e tecnologia operacional. Registrar premissas e separar fatos de escolhas do cenário.

Chapter 03 — Carta de Governança

Criar uma carta com supervisão do conselho, responsabilidade executiva, proprietários de políticas, autoridade de aceitação de risco, escalonamento, exceções e assurance independente.

Chapter 04 — Aplicabilidade Regulatória

Construir um registro que relacione jurisdições, atividades, dados, setores, contratos e sistemas regulados às obrigações aplicáveis, com fonte autoritativa, responsável e data de revisão.

Chapter 05 — Arquitetura de Controles

Separar objetivo, atividade, implementação, evidência, proprietário, frequência, método de teste e obrigações mapeadas. Evitar duplicação quando um controle eficaz atende vários requisitos.

Chapter 06 — Taxonomia de Risco

Criar taxonomia comum para riscos cibernéticos, privacidade, IA, resiliência, reporte financeiro, fornecedores, operação, jurídico e estratégia, com critérios consistentes de impacto e risco residual.

Chapter 07 — Inventário de Ativos e Serviços

Manter inventários autoritativos de serviços, aplicações, infraestrutura, dados, IA, OT, fornecedores, identidades e dependências críticas com proprietário e estado de ciclo de vida.

Chapter 08 — Governança de Dados

Definir classificação, finalidade, retenção, minimização, residência, acesso, compartilhamento, descarte e linhagem, vinculando controles a sistemas, fornecedores, IA e direitos de privacidade.

Chapter 09 — Identidade e Acesso

Definir ciclo de identidade, privilégios, autenticação, federação, segregação de funções, recertificação, identidades de serviço e acesso emergencial.

Chapter 10 — Configuração Segura

Estabelecer baselines aprovados para endpoints, servidores, nuvem, rede, bancos de dados, SaaS, OT e ferramentas de segurança com gestão de desvios e evidências.

Chapter 11 — Gestão de Vulnerabilidades

Definir descoberta, validação, priorização, remediação, exceções, controles compensatórios e verificação considerando explorabilidade, exposição, criticidade e ameaça.

Chapter 12 — Desenvolvimento Seguro

Integrar requisitos, modelagem de ameaças, revisão de código, dependências, testes, aprovação de release, proveniência, segredos e resposta a vulnerabilidades.

Chapter 13 — Governança de IA

Inventariar casos e modelos, classificar risco e documentar finalidade, supervisão humana, proveniência de dados, avaliação, segurança, privacidade, transparência, monitoramento, mudanças e incidentes.

Chapter 14 — Segurança de IA

Abordar prompt injection, uso inseguro de ferramentas, vazamento de dados, cadeia de suprimentos, integridade RAG, permissões de agentes, logs, guardrails, red teaming e comportamento seguro em falhas.

Chapter 15 — Engenharia de Privacidade

Traduzir obrigações em controles para avisos, direitos, minimização, finalidade, retenção, segurança, operadores, transferências internacionais e decisões automatizadas.

Chapter 16 — Risco de Terceiros

Definir intake, risco inerente, due diligence, contratos, requisitos de segurança/privacidade, monitoramento, issues, concentração, quartas partes e encerramento.

Chapter 17 — Governança de Nuvem

Definir landing zones, contas, IAM, rede, criptografia, logging, chaves, postura, backup, resiliência, proprietários e responsabilidade compartilhada.

Chapter 18 — Segurança OT e ICS

Separar segurança operacional e restrições de TI comum. Incluir segmentação, acesso remoto, visibilidade, mudanças, monitoramento, fornecedores, backup, recuperação e incidentes.

Chapter 19 — Detecção e Logs

Definir logging de segurança, privacidade, IA, aplicações, nuvem, identidade e OT, com retenção, integridade, sincronização, detecções e preservação de evidências.

Chapter 20 — Resposta a Incidentes

Criar classificação, comando, investigação, contenção, erradicação, recuperação, avaliação jurídica/privacidade, notificação, comunicações, evidências e lições aprendidas.

Chapter 21 — Continuidade de Negócios

Mapear serviços críticos a objetivos de recuperação, dependências, pessoas, instalações, fornecedores, tecnologia, dados e processos alternativos, com testes realistas.

Chapter 22 — Recuperação de Desastres

Definir níveis de recuperação, integridade de backups, restauração, ambientes alternativos, dependências, validação e cyber recovery.

Chapter 23 — Controles Financeiros e de TI

Integrar ITGC, acessos, mudanças, operações, interfaces, relatórios, controles automatizados, evidências, deficiências e remediação ao GRC empresarial.

Chapter 24 — Operações de Compliance

Projetar intake de obrigações, mapeamento, calendário de testes, evidências, issues, mudanças regulatórias, políticas, atestações, exceções e relatórios.

Chapter 25 — Assurance e Auditoria

Definir monitoramento de primeira linha, desafio de segunda linha, independência de auditoria, amostragem, testes, papéis de trabalho, evidência, classificação de achados e validação de fechamento.

Chapter 26 — Métricas e KRIs

Selecionar métricas orientadas a resultados para exposição, desempenho de controles, exceções, remediação, incidentes, terceiros, IA, privacidade, resiliência e auditoria.

Chapter 27 — Relato Executivo

Reportar ao conselho e executivos exposição, eficácia, mudanças significativas, risco aceito, remediação vencida, riscos emergentes, incidentes e decisões necessárias.

Chapter 28 — Gestão de Evidências

Definir fonte, proprietário, frequência, referência imutável, método de coleta, retenção, acesso, qualidade e vínculo com controles e testes.

Chapter 29 — Exercício Integrado

Executar cenário combinando comprometimento de fornecedor, exposição cloud, fluxo com IA, impacto de privacidade, interrupção operacional e possível obrigação de divulgação.

Chapter 30 — Resposta da Gestão

Documentar decisões executivas, aceitação ou remediação de risco, responsáveis, prazos, recursos, comunicação e validação posterior.

Chapter 31 — Avaliação do Capstone

Avaliar completude, rastreabilidade, desenho de controles, qualidade de evidência, raciocínio de risco, coordenação e distinção entre requisito e interpretação.

Chapter 32 — Publicação e Melhoria Contínua

Congelar o pacote final somente após verificar publicação do predecessor, fontes, paridade trilingue, integridade de artefatos, QA documental/render, acessibilidade, segurança do repositório, proveniência e aprovação humana final.